

GlowProof

Privacy & Data Handling

What's stored, what isn't, and why - every claim tied to code

A short, standalone statement of what GlowProof does and doesn't do with a person's data. Every claim below is enforced in code, referenced by file and line, not asserted as policy on top of a system that could quietly do otherwise.

The photo

Never stored, anywhere, in any form. The uploaded image is held in memory only for the duration of a single request: read from the upload, sent to Perfect Corp over TLS, and discarded the moment the response comes back. It is never written to disk, never logged, never sent to the LLM provider, never sent to Xano, and never cached. `app/main.py`'s `_SESSIONS` dict and the Xano `scans` table both hold *only* the numeric analysis output — concern scores, labels, and mask overlay URLs Perfect Corp itself returned — never image bytes.

What is retained, and why

Data	Where	Why
Concern scores (0–100 per concern)	Xano <code>scans.analysis</code>	The whole product's value proposition — a baseline to compare against later
Generated routine (steps, product type/ingredient, red-light protocol)	Xano <code>scans.routine</code>	So a past result is reopenable without regenerating it
Mask overlay URLs	Same JSON blob	These are Perfect Corp's own signed S3 links, not images we host; they expire (2h) and are simply not shown once stale
Real product search results (title, price, store, link)	Local disk / <code>/tmp</code> cache	Performance only — cuts <code>SerpApi</code> calls on repeat demo runs, never the only path to a result

Nothing above is personally identifying beyond whatever a session id implies (a scan's Xano row id). No name, no email, no account, no login is collected anywhere in the product.

No accounts, no auth, and why that's a deliberate choice, not an oversight

GlowProof has no user accounts. Xano's scan-persistence endpoints carry no authentication. This was evaluated, not defaulted to: the stored payload (scores + a routine) contains no PII, so the marginal privacy benefit of adding auth was judged not worth the complexity it would add under a one-week build. If GlowProof grew beyond a hackathon prototype, adding scoped auth to the Xano endpoints would be the first hardening step before any real user data (even non-image data) accumulated at scale.

Secrets

Perfect Corp, Anthropic, Gemini, SerpApi, and Xano credentials are all environment variables (`.env`, gitignored) — never committed, never hardcoded. The GitHub repository was scanned for accidental secret leakage before being made public (`grep` for common key-pattern prefixes across every tracked file type). Production deployment secrets live in Vercel's own environment variable store, set through the CLI, never checked into source.

The public deployment specifically

The live URL (`glow-proof.vercel.app`) is forced into fixture mode (`GLOWPROOF_FORCE_FIXTURE=1`), independent of whatever a local `.env` says. This isn't a privacy control for *visitor* data — it exists so an anonymous visitor to a public link can't spend the account's real Perfect Corp analysis credit. It has the side effect of meaning nothing a judge does on the public demo ever reaches a real skin-analysis provider at all; every photo a judge uploads there is processed against a canned fixture, not sent anywhere.

Claims discipline, as a privacy-adjacent concern

`app/routine.py`'s system prompt hard-forbids diagnosis language, disease names, and unhedged efficacy claims, and requires hedged phrasing ("studies suggest," "many people see"). This is enforced at generation time, not filtered after the fact — the model is instructed never to produce this content in the first place. The disclaimer ("cosmetic

guidance, not a diagnosis") is permanent UI on the results view, not a dismissible footer a user can close and forget.

Summary for a compliance-minded reviewer

- No image data leaves the request/response cycle it arrived in.
- No PII is collected or stored at any point.
- No accounts, no auth, no tracking.
- All secrets are environment-scoped, never committed, scanned before the repo went public.
- The public demo is hard-gated away from spending real third-party credit or sending real user photos to any live provider.